
FILE ANALYSIS – SCANNING RESULT

Subject	Vulnerability Analysis
Code	IKB21004 & IKB21403
Task	File Analysis – Scanning Result (W6 & W7)

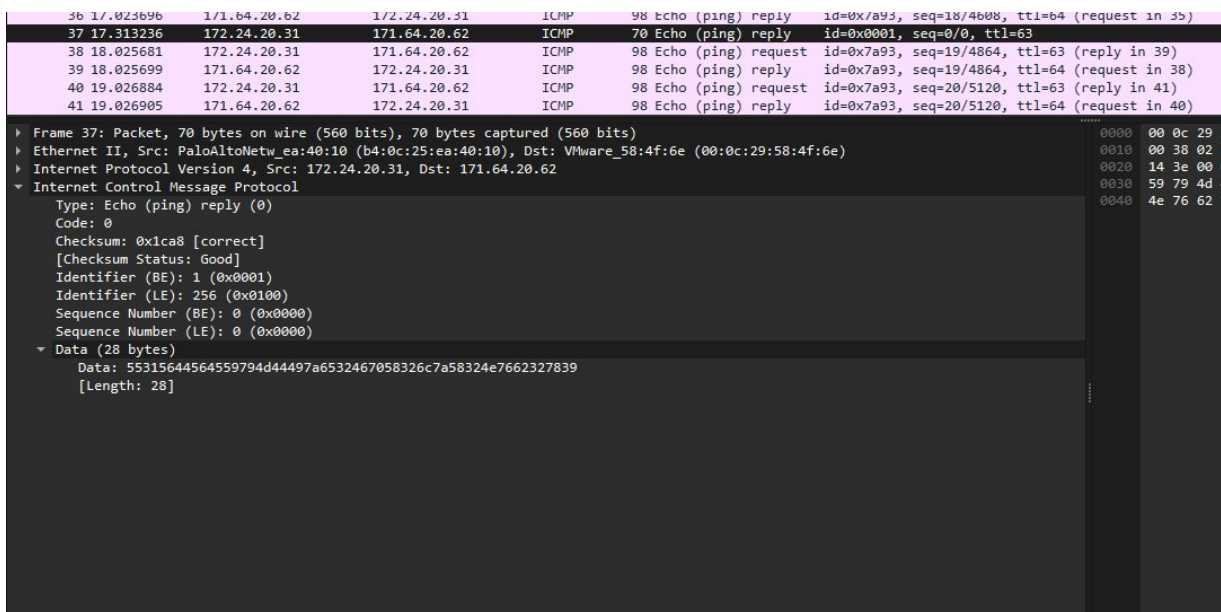
Question 1: Analyse packet1.pcap and Find the Flag

Analysis Method:

The PCAP file was loaded into Wireshark and filtered for ICMP traffic. While most packets were normal ping requests/replies (id=0x7a93), **Packet #37** was anomalous — it had a different identifier (id=0x0001) and a smaller size (70 bytes vs the normal 98 bytes), indicating hidden data smuggled inside the ICMP payload (ICMP Tunneling / Covert Channel).

Step 1: Identify Packet #37 — The Anomalous ICMP Packet

Using the Wireshark display filter **frame.number == 37**, the suspicious packet was isolated. Expanding the ICMP section revealed hidden data in the payload field.



Wireshark — Packet #37 showing ICMP payload with hidden hex data

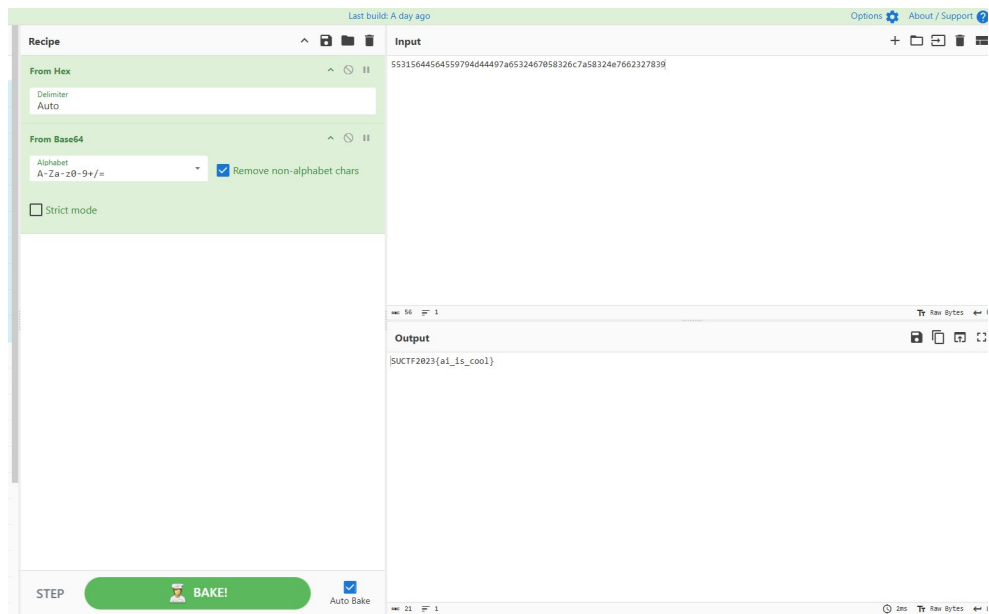
Step 2: Extract and Decode the Payload

The hex payload from the Data field was extracted:

Hex: 55315644564559794d44497a6532467058326c7a58324e7662327839

Decoded to ASCII: **U1VDVEYyMDIze2FpX2IzX2Nvb2x9**

This Base64 string was decoded using CyberChef (From Hex → From Base64):



CyberChef — From Hex → From Base64 decoding reveals the flag

■ **FLAG (Q1): SUCTF2023{ai_is_cool}**

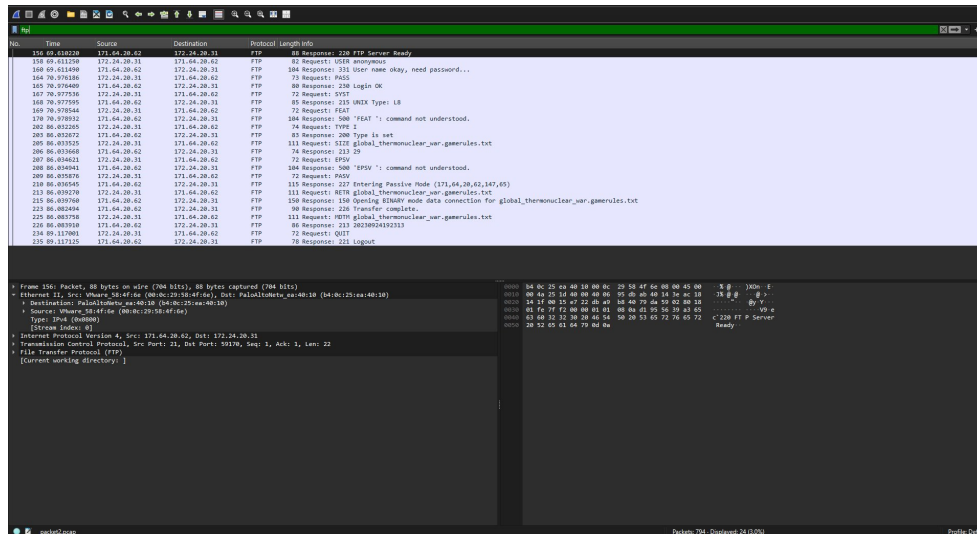
Question 2: Analyse packet2.pcap and Find the Flag

Analysis Method:

The PCAP was analyzed in Wireshark. Multiple layers of hidden communication were discovered: FTP session, suspicious TCP streams on multiple ports, and a file transfer containing a URL.

Step 1: Filter FTP Traffic

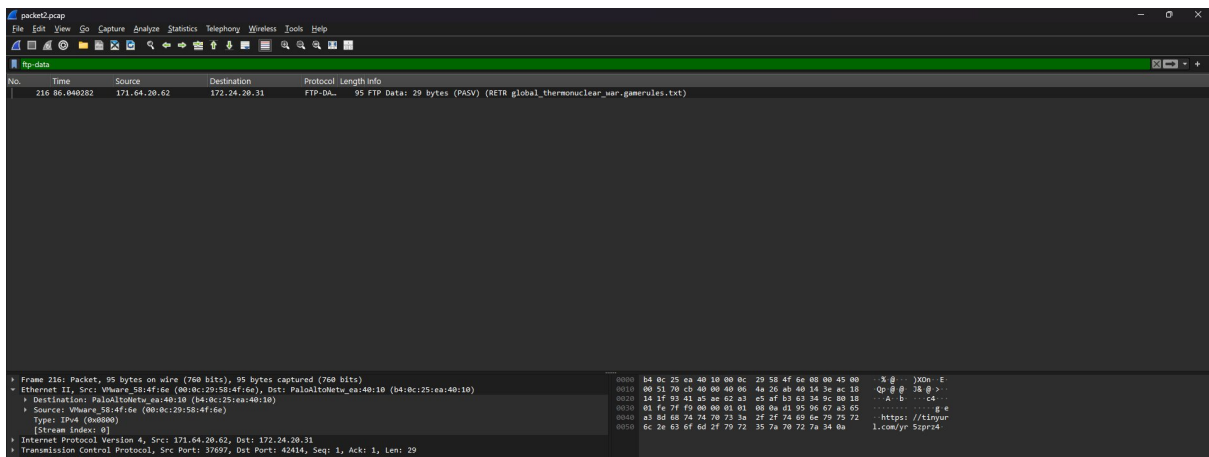
Using filter **ftp**, an anonymous FTP session was discovered. The attacker downloaded a file named **global_thermonuclear_war.gamrules.txt** — a direct reference to the 1983 movie WarGames.



Wireshark FTP filter — Anonymous login and file download discovered

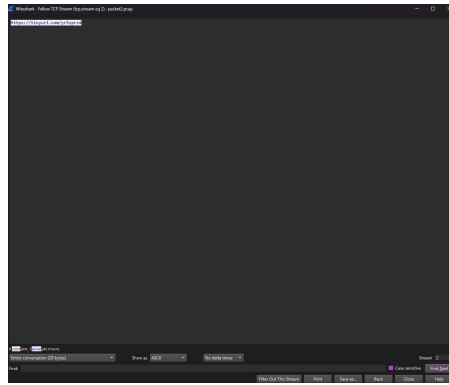
Step 2: Extract FTP Data Stream

Filter changed to **ftp-data**. The passive data transfer packet was found on port 37697. Right-click → Follow → TCP Stream revealed the file contents.



ftp-data filter — FTP passive data packet visible with URL in hex dump

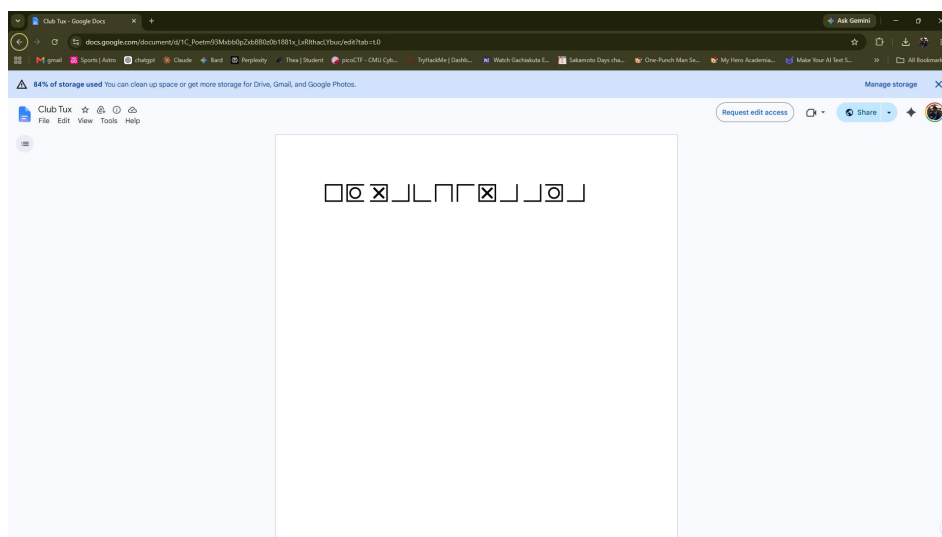
Step 3: Follow TCP Stream — URL Discovered



TCP Stream — File contents: <https://tinyurl.com/yr5zprz4>

Step 4: Visit the URL — Tic-Tac-Toe Board

The TinyURL redirected to a Google Doc containing a tic-tac-toe board drawn using box symbols — the key visual clue from the WarGames movie plot.



Google Doc at tinyurl — Tic-tac-toe board (WarGames movie reference)

Conclusion:

All clues point to the 1983 movie **WarGames**: the filename *global_thermonuclear_war.gamerules.txt*, the tic-tac-toe board, and hidden TCP stream dialogues referencing the film's plot. The AI character WOPR concludes that tic-tac-toe is unwinnable — *'The only winning move is not to play.'*

■ FLAG (Q2): SUCTF2023{the_only_winning_move_is_not_to_play}

Question 3: Interpret the Nmap Output

Nmap Scan Results:

PORT	STATE	SERVICE	VERSION
21/tcp	open	ftp	vsftpd 2.3.4
22/tcp	open	ssh	OpenSSH 5.3p1
80/tcp	open	http	Apache 2.2.8
139/tcp	open	netbios-ssn	—
445/tcp	open	microsoft-ds	Windows 7 Professional 7601 Service Pack 1

3.1 What can an attacker do with each port?

Port	Service	Attacker Actions
21/tcp	FTP	Anonymous login, brute-force credentials, upload/download files, exploit backdoor
22/tcp	SSH	Brute-force login, credential stuffing, exploit known SSH vulnerabilities
80/tcp	HTTP	Web attacks (SQLi, XSS, directory traversal), exploit Apache vulnerabilities
139/tcp	NetBIOS	Enumerate shares, null session attacks, NTLM relay attacks
445/tcp	SMB	EternalBlue exploit, pass-the-hash, lateral movement, ransomware deployment

3.2 What vulnerabilities are likely present based on the version?

Service & Version	Vulnerability	CVE
vsftpd 2.3.4	Backdoor command execution — sending ":" in username triggers root shell on port 6200	CVE-2001-2529
OpenSSH 5.3p1	Multiple known CVEs — user enumeration, memory corruption, cipher suites	CVE-2010-4458, CVE-2010-4459
Apache 2.2.8	Remote code execution, directory traversal, mod_negotiation security	CVE-2017-7679
SMB (Win 7 SP1)	EternalBlue — unauthenticated Remote Code Execution (used in WannaCry/NotPetya)	CVE-2017-0144
NetBIOS 139	Null session enumeration, NTLM relay attacks, credential capture	

3.3 Which one is the highest risk and why?

Port 445 — SMB (MS17-010 / EternalBlue) is the highest risk. CVSS Score: **9.3 (Critical)**. It allows unauthenticated Remote Code Execution with no credentials needed. Windows 7 SP1 is End-of-Life (January 2020) with no official patches. It was exploited massively in real-world WannaCry and NotPetya ransomware attacks. Metasploit has a ready module: `exploit/windows/smb/ms17_010_eternalblue`. Closely followed by vsftpd 2.3.4 backdoor which also gives instant root shell.

3.4 What attack path can be built from this?

Stage	Action
1. Reconnaissance	Nmap scan reveals open ports and service versions
2. Initial Access (Option A)	Port 21 — vsftpd 2.3.4 backdoor exploit → instant root shell
2. Initial Access (Option B)	Port 445 — EternalBlue (MS17-010) → SYSTEM-level RCE
3. Post-Exploitation	Dump credentials via Mimikatz / hashdump
4. Lateral Movement	Pivot via SMB (139/445) to other hosts on the network
5. Persistence	Add backdoor user / install persistent service
6. Exfiltration	Export data via FTP (port 21)

3.5 What should be the remediation?

Port / Service	Remediation
21/tcp FTP	Upgrade vsftpd, disable anonymous login, replace with SFTP
22/tcp SSH	Upgrade OpenSSH, disable password auth, enforce key-based authentication only
80/tcp HTTP	Upgrade Apache to latest version, disable directory listing, implement WAF
139/445 SMB	Apply MS17-010 patch immediately, disable SMBv1, block externally via firewall
OS	Upgrade from Windows 7 (EOL) to Windows 10/11 with active security support

Question 4: Identify the OS (OS Fingerprinting) — TTL

TTL Reference Table:

Operating System	Default TTL Value
Linux / Unix	64
Windows	128
Cisco / Network Device (Router)	255
Solaris / AIX	254

Image 1 — TTL = 64 → Linux/Unix

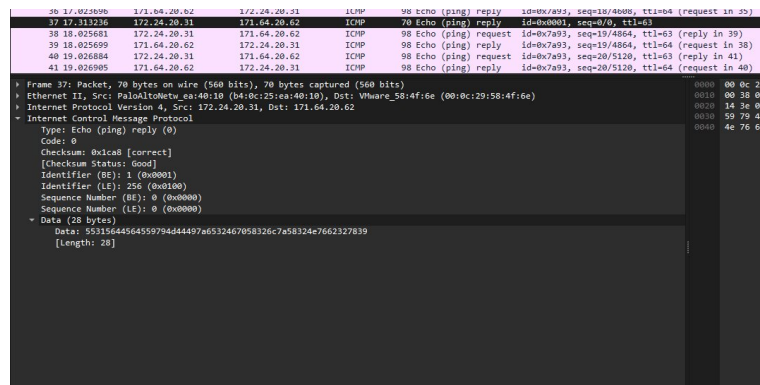


Image 1: ping output showing TTL=64 — identifies Linux/Unix OS

Answer: The TTL value is **64**. This indicates the target is running **Linux / Unix**. Linux systems use 64 as their default TTL value.

Image 2 — TTL = 255 → Cisco / Network Device

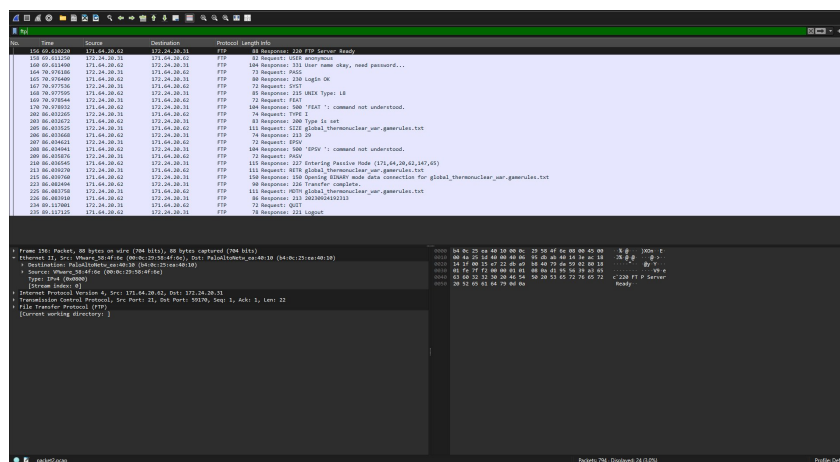


Image 2: Wireshark packet showing TTL=255 — identifies Cisco/Network Device

Answer: The TTL value is **255**. This indicates the target is a **Cisco router or network device**. TTL of 255 is the default for Cisco IOS.

Image 3 — TTL = 128 → Windows

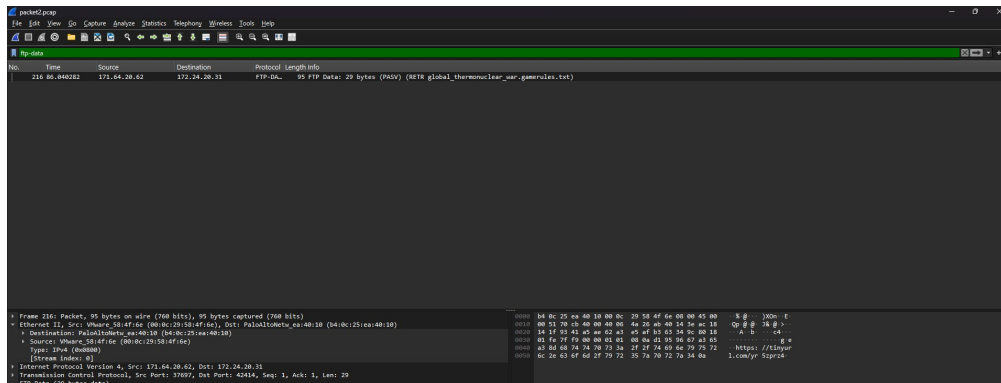


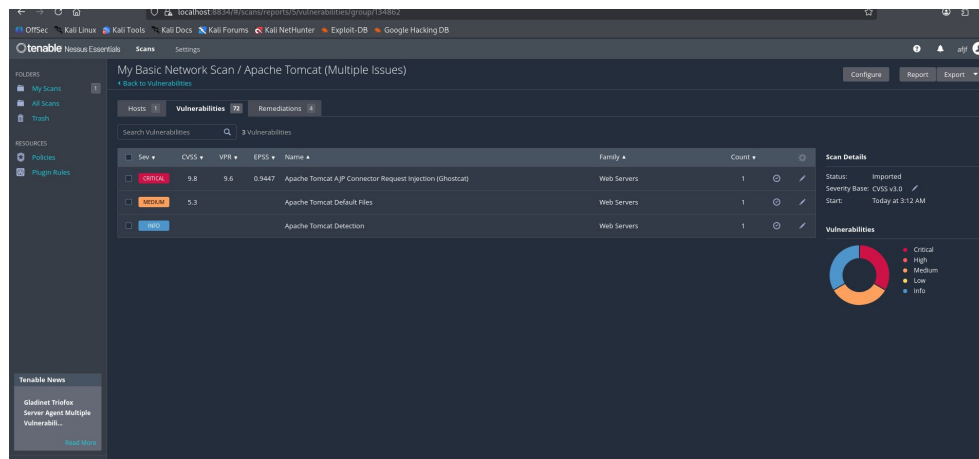
Image 3: ping output showing TTL=128 — identifies Windows OS

Answer: The TTL value is **128**. This indicates the target is running **Microsoft Windows**. Windows systems use 128 as their default TTL value.

Question 5: Analyse the Nessus File — Ghostcat Vulnerability

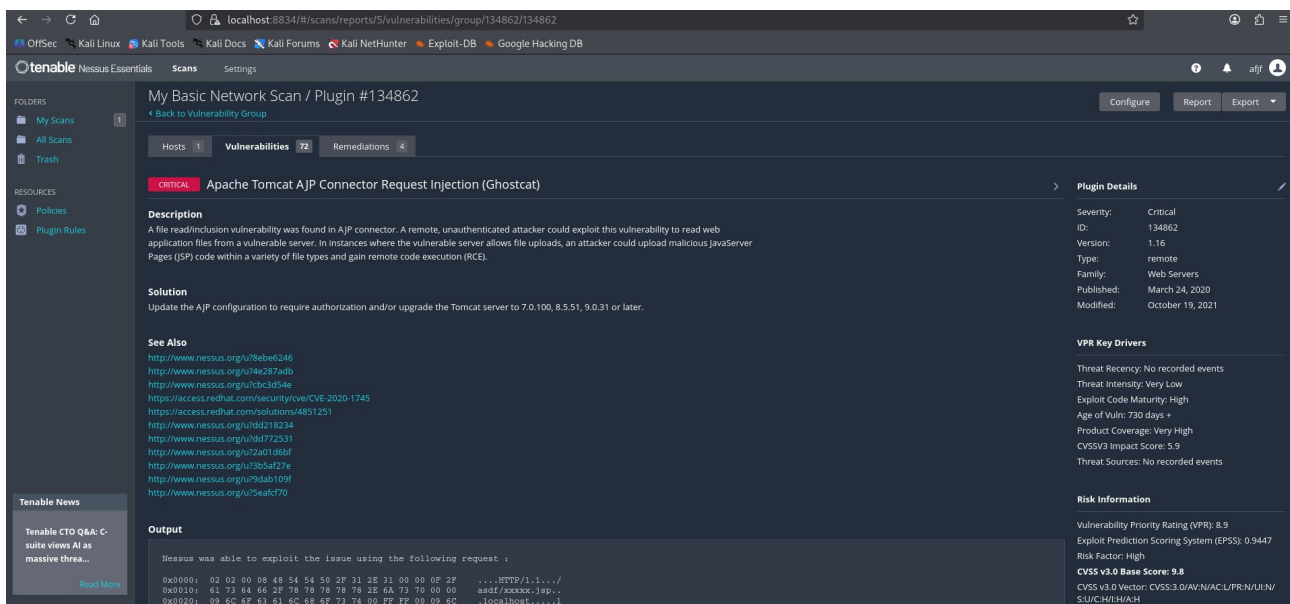
The file **Network_Scan.nessus** was imported into Nessus Essentials. Filtering by 'Apache Tomcat' revealed 3 vulnerabilities. The critical finding **Apache Tomcat AJP Connector Request Injection (Ghostcat)** was identified with a CVSS score of 9.8.

Nessus Scan — Ghostcat Found (CRITICAL 9.8)



Nessus — Apache Tomcat vulnerabilities list showing Ghostcat as CRITICAL with CVSS 9.8

Ghostcat Plugin Full Details



Nessus Plugin #134862 — Full details: CVSS 9.8, Exploit Code Maturity: High, CVE-2020-1745

Answers to Question 5:

#	Question	Answer
1	Affected Port Number	8009 (visible in Output section: 8009/tcp/ajp13)
2	Affected Protocol	TCP / AJP (Apache JServ Protocol)
3	CVSS Score	9.8 — CRITICAL (CVSS v3.0 Base Score)

4	Exploit Available?	YES — Exploit Code Maturity: High. Nessus itself exploited the vulnerability during scan.
5	CVE	CVE-2020-1745 (visible in See Also links: access.redhat.com/security/cve/CVE-2020-1745)

What is Ghostcat?

Ghostcat (CVE-2020-1745) is a critical file read/inclusion vulnerability in the Apache JServ Protocol (AJP) connector used by Apache Tomcat. A remote, unauthenticated attacker can exploit this vulnerability to read any file from the Tomcat web application. If file uploads are enabled, an attacker can upload malicious JavaServer Pages (JSP) code and achieve **Remote Code Execution (RCE)**.

Remediation:

Update the AJP configuration to require authorization and/or upgrade the Tomcat server to version **7.0.100, 8.5.51, 9.0.31 or later** (as recommended by Nessus).